

BREAKOUT

Deep-Dive into Power Platform Managed Security

Tomas Prokop
Raphael Pothin

PPCC 2025 DAY 3

About Us



Raphael Pothin



Lead Power Platform Reliability Engineer
at Manulife

Focus Areas:

- 🔒 Power Platform Governance & Security
- 🚀 Platform Engineering & Solution Architecture
- 🔑 Developer Experience & AI Assisted Development



rpothin on GitHub



Raphael POTHIN on LinkedIn



raphaelpothin.bsky.social on Bluesky



Tomas Prokop



Power Platform Architect
at NETWORK

Focus Areas:

- 📚 Power Platform Solution Architecture
- 🚀 Code-First Development & CI/CD Automation
- 🔑 Governance, Security & Delivery Best Practices



TomProkop on GitHub



Tomas Prokop on LinkedIn



prokopus.com on Bluesky

Learning Objectives



Build Enterprise-Grade Power Platform Security

Master Managed Security with Security Hub (proactive posture management) and Sentinel (reactive incident detection). Understand audit log pipelines and security best practices.



Investigate Security Incidents Effectively

Navigate Sentinel during Power Platform security incidents, identify when security data alone is insufficient, and discover blind spots in security monitoring configurations.



Leverage Operational Intelligence for Security Context

Recognize when Application Insights provides critical security investigation context, correlate operational telemetry with security events, and reduce false positives.

The 2 AM Sentinel Alert



The Triggering Event

Microsoft Sentinel Alert



Time: 02:17 AM



Severity: High



Alert: "Dataverse Audit Logging Potentially Disabled"



Details: No audit activity for 1+ hour, possible evasion tactic



The Investigation Challenge:

- ? Was logging disabled intentionally or by configuration error?
- ? What happened during the hour+ blackout period?
- ? Is this an active attack or operational issue?
- ? How do we investigate without audit logs?



The Challenge

Your Security Team's Context



Strong in: Security investigation methodologies



Experts at: Threat detection and incident response



Blind spot: No audit logs = no visibility



Missing: Alternative data sources for investigation



Our Investigation Path:

Discover what security monitoring can't see when audit logs fail
Find alternative data sources to understand what actually happened

BUT WAIT A MINUTE...

HOW DID WE GET HERE EXACTLY?

imgflip.com



The Foundations of Security + Observability



Managed Security: The Complete Landscape

Security Posture Management

Intelligent guidance for enterprise-grade security

Security Score

Recommendations

Data Protection & Privacy

Confidentiality and encryption controls

Customer Managed Keys

Data Masking

Microsoft Purview Integration

Advanced Connectors Policies

Data (DLP) Policies

VNet Integration

Identity & Access Management

Authorized access controls

Tenant Isolation

Conditional Access Policies

IP Cookie Binding

IP Firewall

Sharing Limits

Admin Privileges

Guest Access Controls

Client app access

Compliance

Regulatory requirements adherence

Customer Lockbox

Audit Logs

Threat Protection

Detection and monitoring

Microsoft Sentinel Integration

Enhanced protection of Copilot Studio agents

**Managed Environments required*

Four Pillars of Security Observability

Proactive Visibility



Security Score & Recommendations

Why it matters: Provides proactive risk assessment and prioritized remediation guidance directly in Power Platform Admin Center.

How to use: Regular security posture reviews, track score trends, implement high-priority recommendations to prevent incidents before they occur.



Microsoft Purview Data Map Integration

Why it matters: Unified data governance across Dataverse - automatically classifies columns using sensitivity information types, applies sensitivity labels, and maps data lineage across Power Platform environments.

How to use: Register Dataverse as Data Source, configure automated scans for table classification, review sensitivity labels on columns, track data movement patterns.

Reactive Detection



Microsoft Sentinel Integration

Why it matters: Unified platform correlates audit logs with enterprise security intelligence. AI-driven analytics continuously scan for anomalies, automated playbooks orchestrate incident response, and KQL-based hunting queries enable proactive threat investigation across workloads.

How to use: Deploy Microsoft Business Applications solution for Sentinel, enable data connectors, activate ASIM parsers and analytics rules, configure automated response playbooks for containment.



Enhanced Protection of Copilot Studio Agents

Why it matters: Runtime monitoring of AI agents for prompt injection, malicious queries, and unauthorized data access attempts in real-time.

How to use: Enable agent protection policies, monitor conversation patterns, establish AI safety guardrails and behavioral baselines.

The Audit Pipeline to Sentinel



Step 1: Power Platform Generates Audit Logs

- ✓ User actions, system operations captured
- ✓ Coverage: Apps, Automate, Dataverse, Copilot
- ✓ Rich structure: Who, What, When, Where, How
- ✓ Flows through Office 365 Management API



Step 2: Microsoft Purview Audit Solution

- ✓ Audit log aggregation and centralization
- ✓ Compliance search and data retention
- ✓ Gateway to Sentinel data connectors
- ✓ Regulatory compliance management



Step 3: Microsoft Sentinel Platform

- ✓ Business Apps solution
- ✓ ASIM parsers + Analytics rules
- ✓ Workbooks + Hunting queries
- ✓ Automated playbooks (Logic Apps)

Microsoft Sentinel Business Apps Solution



Enterprise-Ready



Unified Solution

- ✓ **Replaces:** Separate Power Platform & Dynamics 365 solutions
- ✓ **Covers:** Power Platform, Dynamics 365 CE, Dynamics 365 F&O
- ✓ **Deploy from:** Microsoft Sentinel Content Hub



Data Connectors

- **Power Platform Admin Activity** - Admin logs
- **Dataverse Activity** - Dataverse & model-driven apps
- **Power Automate Activity** - Flow execution logs



Content Library



50+ Analytics Rules

Anomalous user activity • Audit deletion • Bulk operations • Privilege escalation • Unauthorized geo access • Mass deletion • Malicious links • DLP policy changes



Hunting Queries + Workbooks

Proactive hunting: Cross-environment exports, USB exfiltration, identity management anomalies

Visualization: Dynamics 365 Activity workbook for comprehensive monitoring



Automated Playbooks

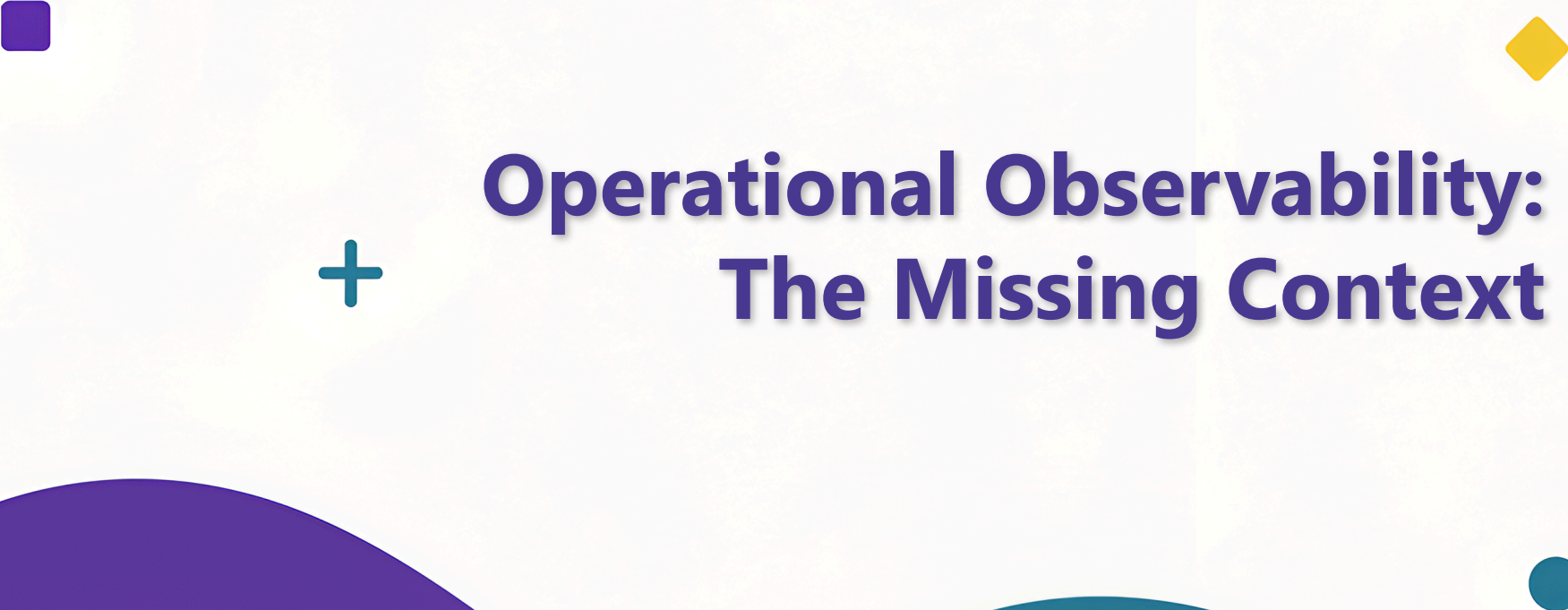
SOAR capabilities: User blocklist management, manager notifications, Teams/Outlook approval workflows, SharePoint site tracking

 **Transition Period:** Microsoft Sentinel is moving to the Defender portal for unified SIEM+XDR security operations. Defender portal is the future home of security for Power Platform.



Demo Time





+

Operational Observability: The Missing Context



Out-of-the-Box Operational Telemetry



The Pipeline

 Dataverse •  Model-Driven Apps
 Canvas Apps •  Power Automate •  Copilot Studio



 Application Insights



 Log Analytics



Telemetry Categories

 **Performance:** Page loads (form, dashboard, grid), response times, duration metrics, network latency

 **Operations:** Web API & Organization Service requests, plug-in execution, SDK operations, flow runs

 **Behavior:** User sessions, screen navigation, app interactions, unique users, device types

 **Dependencies:** UCI network requests, external API calls, connector usage, integration patterns

 **Errors:** Exceptions with stack traces, sync failures, error codes, problematic operations

Extending Observability with Custom Code



Extensibility Points

Dataverse Plug-ins (Microsoft)

- ILogger interface integration
- Custom traces • Exception tracking • Performance metrics

Custom API Logging Pattern

- Unified logging endpoint for Power Apps & Power Automate
- Consistent telemetry structure • Custom event types

Implementation:

```
logger.LogTrace("Validation: {result}", result);
```



Monitoring Value

Enhanced Performance Diagnostics

Out-of-box: "Average execution time 2.5 seconds"

Custom: "Database query 1.8s, API call 0.5s, validation 0.2s"

→ Pinpoint performance bottlenecks

Proactive Error Detection & Resolution

Out-of-box: "Plugin execution failed"

Custom: "Connection timeout after 3 retries, fallback to cache successful"

→ Reduce MTTR with detailed context

Unlocking the Operational Intelligence Layer



Your Journey Map



Power Platform Admin Center

Manage → Data export → App Insights

"A few clicks from governance to operational insights"



Application Insights

Azure Portal → Application Insights

"From operational data to insights and stories"



Hidden Stories



User Behavior: Sessions, navigation, feature adoption



Performance: Response times, bottlenecks, capacity



Integrations: External calls, connectors, dependencies



Business Logic: Process execution, custom events



The Unexpected Value

These stories reveal **why it happened**, **who was involved**, and **what the business impact was** — not just what happened.



Demo Time



The Convergence in Action

+



When Two Worlds Converge



Security Data

Security Event

- Audit logs
- Security events
- User actions
- Access patterns



Convergence

Confident Decisions

Security + Operations = Context



Operational Data

Business Context

- Performance patterns
- Dependencies
- Business timing
- Usage context

Enhanced Investigations with Operational Data



Sentinel Reveals the Path

Confirm Audit Disabled

```
DataverseActivity
| where OriginalObjectId has "Disable" and has "Audit"
| project TimeGenerated, UserId, InstanceUrl
```

Discover: Flow Created After Audit Disabled

```
PowerAutomateActivity
| where EventOriginalType == "CreateFlow"
| where UserUpn =~ suspicious_user
| project FlowDetailsUrl, TimeGenerated
```

Cross-Platform Activity Check

```
union PowerAutomateActivity, PowerPlatformAdminActivity,
    PowerAppsActivity, PowerPlatformConnectorActivity
| where TimeGenerated between (t1 .. t2)
| where ActorName =~ suspicious_user
```



Sentinel Finding: Flow created after audit disabled

But what did it DO and HOW?



App Insights Reveals the Truth

Massive Data Extraction

```
AppRequests
| where Url contains "contact"
| extend QueryType = case(Url contains "$top", "Batch", Url contains
"$select", "Selective", "Full")
| summarize Count = count() by QueryType
```

Extraction Performance Revealed

```
AppDependencies
| where Target == "contact"
| extend Duration = DurationMs, Type = DependencyType
| summarize Operations = count() by bin(Duration, 1000)
```

Exfiltration Method Discovered: HTTP Action

```
AppDependencies
| where Type == "Http" and Data contains "POST"
| where Target !contains "microsoft"
```

✓ **App Insights Confirmation:** Flow extracted a massive number of contacts via API
Posted to external endpoint via HTTP



Demo Time

The Continuous Improvement Mindset



Hunting Queries

Proactive Search:

- Save investigation query as hunting query
- Schedule regular execution
- Find similar patterns before they alert

Our Alert: Hunt for bulk operations not matching known pattern



Analytic Rules

Automated Detection:

- Create rule from investigation findings
- Add operational context checks
- Reduce false positives automatically

Our Alert: Rule excludes monthly schedule window



Automation

Orchestrated Response:

- Playbooks query both data sources
- Automated correlation checks
- Intelligent alert enrichment

Our Alert: Playbook auto-checks operational patterns



The Continuous Improvement Cycle

Alert

Detect



Investigate

Converge



Learn

Hunting



Improve

Rules



Automate

Playbooks



Building Your Dual Observability Strategy for Enhanced Security



Three-Layer Security Architecture



Layer 1: Foundation

Security Hub

- Proactive posture management
- Risk reduction before incidents
- Power Platform admins
- Prevention-focused



Layer 2: Detection

Microsoft Sentinel

- Reactive incident investigation
- Threat detection and response
- Security teams and SOC
- Investigation-focused



Layer 3: Enhancement

Application Insights

- Operational context support
- Investigation enhancement
- Security + Operations teams
- Context-focused



Architecture Principle

Security and operational monitoring converge through **architecture and integration patterns**, not through a single unified dashboard. Sentinel becomes the correlation platform where both data sources meet.

Business Value Framework



Managed Security

Comprehensive Protection:

- **✓ Prevention & Detection:** Proactive posture management combined with AI-driven threat intelligence
- **✓ Faster Response:** Reduced MTTD and MTTR for security incidents
- **✓ Compliance Built-In:** Automated audit and reporting capabilities



Measurable Impact:

Lower incident frequency, faster detection and response, reduced compliance burden



Operational Context

Investigation Excellence:

- **✓ Rapid Triage:** Minutes vs. hours to identify false positives and legitimate threats
- **✓ Team Efficiency:** Security focuses on real threats, operations provides context
- **✓ Business Protection:** Avoid unnecessary disruption while maintaining security



Measurable Impact:

Reduced alert fatigue, improved rule accuracy, better cross-team collaboration



**More details on what we
covered**



Sentinel Audit Tables

 PowerPlatformAdminActivity

 PowerPlatformAdmin

- **EventOriginalType:** EnvironmentPropertyChange, GovernanceApiPolicyOperation, PutConnection
- **Properties/PropertyName:** SecurityGroupId, isolation_policy.enabled, guest access
- **EnvironmentId, OrganizationId** (tenant), **ActorUserId** (AAD object ID)

 PowerAutomateActivity

 PowerAutomate

- **EventOriginalType:** CreateFlow, EditFlow, DeleteFlow, RunFlow
- **FlowConnectorNames:** Http, Microsoft Dataverse (connector list)
- **ActorName, ActorUserId** (AAD object ID)

 DataverseActivity

 Dataverse

- **Message:** ExportToExcel, Update, Delete, BulkDelete, Associate (share)
- **EntityName, EntityId:** Target table/record
- **Fields[]:** Changed attributes (e.g., isauditenabled, roles)
- **SystemUserId** (AAD object ID), **InstanceUrl, ResultStatus**

App Insights Tables

 AppRequests

 Dataverse

 Power Automate

Dataverse Web API: name="Web API Request" or "Organization Service Request"

- **operation_Name:** POST /api/data/v9.0/ExportToExcel
- **url:** Full Dataverse URL, **user_Id** (AAD object ID)

Power Automate Runs: customDimensions.resourceProvider="Cloud Flow"

- **customDimensions.Data.tags.xrmWorkflowId:** Flow GUID
- **customDimensions.resourceId:** Logic app ID

 AppDependencies

 Dataverse

 Power Automate

Flow Actions: customDimensions.Data.actionType: Http, OpenApiConnection

- **customDimensions.Data.apiName:** connector name (empty=HTTP)
- **customDimensions.tags.xrmWorkflowId:** Flow GUID, **name:** action name
- **success:** true/false (use for failure detection)
- ⚠ **HTTP URL NOT logged**

Dataverse SDK: type startswith "SDK" (SDKRetrieve, SDKUpdate, etc.)

- **target:** Entity name, **customDimensions.entityId, customDimensions.entityName**

Plugins: type="Plugin", target: Fully qualified type name

- **customDimensions.entityName, customDimensions.pluginName**

 AppExceptions

 Dataverse

- **type, outerType:** Exception type (e.g., CrmObjectNotFoundException)
- **outerMessage:** Exception message
- **customDimensions.entityId, customDimensions.entityName**
- **customDimensions.exceptionSource:** Plugin path
- **customDimensions.pluginName, customDimensions.depth**

Sentinel Templates: Privileged & Unauthorized Access

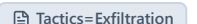
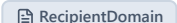
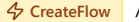
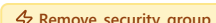
Detection	Logic & Data Sources	
Security role abuse	 Create →  Associate → ( Disassociate or  Delete) on  role within  2-day window in  DataverseActivity via  Dataverse	
Manager hierarchy bypass	 Update on  organization/systemuser where  ishierarchysecurityenabled=False or user assigns self as  parentsystemuserid or self to  monitored_position_ids in  DataverseActivity via  Dataverse	
Privileged Entra role added	 Add member to role where  TargetRole in  D365 Admin / PP Admin / Fabric Admin in  AuditLogs via  AzureActiveDirectory	
Breached identity accessing Power Platform	 Sign-in where  RiskEventTypes not empty and  Appld in  Power Platform apps in  SigninLogs via  AzureActiveDirectory	
Bulk app sharing to guest users	 PowerAppPermissionEdited where shared with  ≥5 unique guests where  RecipientDomain not in  allowed_domains in  PowerPlatformAdminActivity via  PowerPlatformAdmin > join guest invitations where  14-day lookback in  AuditLogs via  AzureActiveDirectory	

Sentinel Templates: Data Exfiltration - Mass Operations

Detection	Logic & Data Sources	
Mass export to Excel	 ExportToExcel where  >14d baseline or >10k default in  DataverseActivity via  Dataverse	
Bulk retrieval baseline deviation	 RetrieveMultiple where current count  >14d historical baseline in  DataverseActivity via  Dataverse	
TDS endpoint (SQL) abuse	 ExecutePowerBISql where  first-time use in environment in  DataverseActivity via  Dataverse > join where  UserId or IPAddress has alerts in  SecurityAlert via  AzureActiveDirectoryIdentityProtection	
Web API abuse	 UserSignIn where  Appld: 51f81489... across  >10 environments within  2-hour window in  DataverseActivity via  Dataverse > join  SigninLogs via  AzureActiveDirectory	
High-risk connector deployed	 PutConnection where environment in  sensitive_environment_id in  PowerPlatformAdminActivity via  PowerPlatformAdmin	
Mass deletion of records	 Delete where  >10k/day or  BulkDelete where  scheduled job in  DataverseActivity via  Dataverse	

Table Log Analytics Tables **Connector** Sentinel Connectors **Event** Operations/Actions **Resource** Target Resources **Field** Properties/Attributes **Threshold** Detection Criteria **Config** Watchlists/Variables → Then |> Join

Sentinel Templates: Data Exfiltration - Insider Threats

Detection	Logic & Data Sources	
Terminated user export	 /  /  /  where user in  within  of termination in  via 	
Email data theft	 where  and  via  > join user in  > join   where  not in  with attachments in  via 	
USB data theft	 where  > join  where  matches and copied to  > join user in  via 	
Departing employee flows	 /  where user in  in  via 	
Defense evasion & exfiltration chain	 and  in  via  > join  in  via  > join exfiltration alerts in  via 	

Sentinel Templates: Defense Evasion & External Attacks

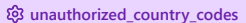
Detection	Logic & Data Sources	
Audit logging disabled	 Update /  UpdateAuditSettings on  organization where  isauditenabled=False or  isuseraccessauditenabled=False or  isreadauditenabled=False in  DataaverseActivity via  Dataaverse	
DLP policy tampering	 Update /  Delete on  DlpPolicy in  PowerPlatformAdminActivity via  PowerPlatformAdmin	
Phishing via app distribution	 CreatePowerApp →  LaunchPowerApp by  >2 users/hour in  PowerPlatformAdminActivity via  PowerPlatformAdmin > join  UrlClick to malicious URL in  UrlClickEvents via  MicrosoftThreatProtection > join threat intel in  ThreatIntelligenceIndicator via  ThreatIntelligence	
Unauthorized geo access	 LaunchPowerApp in  PowerPlatformAdminActivity via  PowerPlatformAdmin > join  SignInLogs where  Location in  unauthorized_country_codes via  AzureActiveDirectory	
Malware in doc mgmt	 FileMalwareDetected in  OfficeActivity via  Office365 > join  FileUploaded in  DataaverseActivity where  SiteUrl in  Dataaverse SharePoint sites	

Table Log Analytics Tables **Connector** Sentinel Connectors **Event** Operations/Actions **Resource** Target Resources **Field** Properties/Attributes **Threshold** Detection Criteria **Config** Watchlists/Variables → Then |> Join

THANK YOU

PPCC 2025 DAY 3